

Incident Response Plan

RFQ 75D301-26-Q-00146 — Modernized VAERS Reporting Application · Frasier Digital, LLC Submitted with the proposal per the PWS Standard-4 deliverables table ("as part of Proposal") and Amendment 0001 Q&A 160. This plan governs contractor-side incident response during performance; it will be aligned to CDC/OCIO incident-response procedures at kickoff and updated annually or upon significant change, per Standard-4.

1. Scope and definitions

Covers any suspected or confirmed incident affecting work performed under this contract: the application and its code, configuration, and pipelines in the CDC-managed Azure environment; contractor development environments (which hold **no production data, PHI, PII, or other Government non-public information** prior to ATD/ATO issuance — Q&A 83); credentials and Government-furnished equipment; and the pre-award prototype environment (synthetic data only). An *incident* is any event that actually or potentially jeopardizes confidentiality, integrity, or availability of information or systems in scope, including compromise, malware, unauthorized access or disclosure, loss or theft of equipment or credentials, and supply-chain compromise of a dependency.

2. Roles

Role	Person	Responsibility
Incident Response Lead	Joseph Frasier, PM (Key)	Declares incidents, owns notifications, directs response, approves closure
Technical Lead	Ryan Daley (Key)	Containment and eradication actions; forensically sound evidence handling
All team members	—	Report suspected incidents to the IR Lead immediately upon discovery; annual security-awareness, privacy, and records-management training before access (PWS Section 11)

The reporting channel operates independently of the management chain: any team member may invoke it directly, and notification is never queued behind analysis.

3. Response procedure

- 1. Detect and report (continuous).** Sources: Azure/CDC monitoring and scans, CI pipeline alerts (dependency and secret scanning on every commit), developer observation, CDC notice.
- 2. Notify (within 1 hour of discovery).** The IR Lead notifies the COR and the CDC-designated security contact within **one hour** of discovering any suspected or confirmed incident involving Government information or systems, by the channels CDC designates at kickoff, and follows CDC/HHS and US-CERT reporting procedures, including timelines for incidents involving PII/PHI. Notification is made on suspicion — we do not wait for confirmation.

3. **Contain.** Isolate affected components (feature-flag rollback, credential revocation, pipeline freeze, environment isolation) in coordination with CDC/OCIO for anything inside the CDC boundary. Preserve logs and evidence; the application's audit records (event type, time, source, outcome, subject) are retained and protected per the PWS.
4. **Eradicate and recover.** Root cause identified and removed; affected secrets rotated; redeployment from known-good, scanned artifacts; verification testing before restoration.
5. **Document and close.** Written incident report to the COR covering timeline, scope, data affected, actions taken, and residual risk; closure requires COR concurrence.
6. **Learn.** Post-incident review within 5 business days; corrective actions tracked as POA&M items with the remediation clocks in the RFQ (critical 15 days, high 30 days, medium 60 days per Amendment 0001 Q&A 15); recurrence-prevention changes (tests, controls, process) merged before the review closes.

4. Specific scenarios

Scenario	Immediate action beyond §3
Lost/stolen GFE laptop or PIV	Report to COR + CDC service desk within 1 hour; credential suspension request
Credential or secret exposure in code	Rotate immediately; purge from history; audit use since exposure
Vulnerability disclosed in a dependency	Assess exploitability same day; patch or mitigate within POA&M clocks; document in the vulnerability log
Prototype site (pre-award) defacement or compromise	Take offline (uptime monitor alerts within minutes), rebuild from source, restore; no Government data is present by design
Suspected PII/PHI exposure (post-award)	Treat as presumptive breach: 1-hour COR/CDC notification, CDC/HHS breach procedures govern; contractor does not make external notifications

5. Maintenance

Reviewed and updated annually, upon significant change to the technical or operational environment, and after every incident (PWS Standard-4). The version aligned with CDC procedures is delivered as part of the security and privacy documentation package supporting ATD issuance.

Approved: Joseph Frasier, Founder and Managing Member, Frasier Digital, LLC · Date: **[FLAG: sign date]**